

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- By the end of this lecture, you will be able to describe the principal components of cloud network infrastructure and the security considerations specific to each.
- By the end of this lecture, you will be able to explain the security differences between public internet connectivity, dedicated private connections, and VPN-based connectivity for cloud workloads.
- By the end of this lecture, you will be able to identify the security risks introduced by software-defined networking and VLAN-based segmentation in multi-tenant cloud environments.
- By the end of this lecture, you will be able to explain how BGP hijacking works and why routing protocol security is a material concern for cloud security practitioners.
- By the end of this lecture, you will be able to distinguish between network availability and network security, and explain why a highly available network can still be fundamentally insecure.

Introduction

Cloud network infrastructure is the connective tissue that links users to cloud services, cloud services to one another, and cloud regions to the global internet. Every API call, every database query, every file transfer traverses a layered architecture of physical connections, logical overlays, routing protocols, and management interfaces. For a Cloud Security Practitioner, understanding this architecture is not optional: the network layer is where data is most exposed in transit, where misconfiguration risk is highest, and where adversaries most frequently find their initial foothold.

A critical framing error that affects many security assessments is equating network security with network availability. A cloud network can be performing perfectly, with low latency and high throughput, while sensitive data traverses unencrypted paths between services, a misconfigured routing rule exposes a management interface to the public internet, and VLAN segmentation errors allow traffic to leak across tenant boundaries. Availability is a necessary condition for usefulness; it is not sufficient for security. Domain 3 requires candidates to hold both dimensions simultaneously and to evaluate cloud network architectures against both.

The network components covered in this lecture correspond directly to the control points a CCSP-level practitioner must be able to evaluate: the type of connectivity chosen for a given workload, the segmentation controls in place between tenants and between network zones, the routing protocol security posture of the environment, the redundancy design of physical and logical paths, and the function of content delivery and load balancing components as termination points for encryption. Each component has a characteristic attack surface and a characteristic set of best-practice controls that a security professional is expected to know and apply.

Core Concepts Explained

Private Backbone Networks and Dedicated Connectivity Services

Definition: Major cloud providers operate private backbone networks that carry inter-data-center traffic without using the public internet, and offer dedicated private connection services (AWS Direct Connect, Azure ExpressRoute, Google Cloud Interconnect) that link customer premises directly to the provider's network edge over dedicated fibre.

Business relevance: Traffic traversing the public internet passes through routing decisions made by dozens of independent carriers with varying security practices. A private backbone or dedicated connection eliminates that exposure for inter-cloud traffic, providing a predictable, provider-controlled path. For workloads with strict compliance requirements or high sensitivity, this is a meaningful risk control.

Cloud Security Practitioner relevance: A Cloud Security Practitioner evaluates connectivity requirements at the start of every cloud workload design: for regulated data (PCI DSS cardholder data, HIPAA ePHI, GDPR personal data), the default assumption should be that public internet transit requires explicit justification, and dedicated private connectivity should be the baseline recommendation.

Real-world example: A global investment bank migrating its trading analytics workload to AWS evaluates connectivity options. The workload involves real-time market data and proprietary algorithmic models that are highly sensitive both commercially and regulatorily. The security practitioner leading the design review recommends AWS Direct Connect rather than public internet transit. The rationale is documented: public internet routing introduces unpredictable path changes, potential BGP hijacking exposure, and transit through network infrastructure not governed by the provider's security controls. Direct Connect provides a dedicated 10Gbps connection from the bank's co-location facility directly to the AWS network edge, with all traffic remaining on a provider-controlled path. The added cost is approved as a necessary security control, and the connectivity design is documented in the workload's risk treatment plan with a reference to the compliance requirement driving it.

Risks or limitations: Using public internet connectivity for sensitive workloads without explicit justification is a common misconfiguration of risk tolerance. The best practice is to classify all cloud workloads by data sensitivity at design time and require documented justification before any workload classified as sensitive is permitted to use public internet transit instead of dedicated private connectivity.

Software-Defined Networking and the Misconfiguration Risk Surface

Definition: Software-defined networking (SDN) allows network configuration, segmentation, and management to be performed through software APIs and management consoles rather than physical reconfiguration. In cloud environments, this means network topology changes happen in seconds but can also introduce errors at the same speed.

Business relevance: SDN is what makes cloud networking operationally agile: network segments can be created, modified, or removed through API calls, enabling rapid deployment and infrastructure-as-code practices. The same capability means that a single misconfigured policy rule can expose a critical segment to an unintended range of sources, and that error propagates instantly across the entire software-defined topology.

Cloud Security Practitioner relevance: A Cloud Security Practitioner treats SDN misconfiguration as one of the highest-probability risk categories in cloud environments. The practitioner's responsibilities include reviewing network security group rules and virtual network configurations as part of every architecture review, requiring infrastructure-as-code practices with version control and peer review for all network configuration changes, and implementing continuous monitoring that alerts on new public-facing exposure of internal resources.

Real-world example: A SaaS company operating a multi-tenant platform on a major cloud provider discovers during a penetration test that a network security group rule added three weeks earlier by a developer testing a new integration had inadvertently opened TCP port 5432 (PostgreSQL) on the database subnet to 0.0.0.0/0, meaning every PostgreSQL instance in that subnet had been reachable from the public internet for three weeks. The developer had intended to open access from a single IP address but made a typographical error in the rule definition. The misconfiguration was not caught because the company's change review process did not include automated validation of network security group changes against a baseline. Following the incident, the company implemented a policy-as-code framework that automatically validates all network configuration changes against defined rules before they are applied, and implemented continuous cloud security posture management tooling that alerts on any new public exposure of database ports.

Risks or limitations: The speed of SDN creates an asymmetry between how quickly a misconfiguration can be introduced and how quickly it can be detected without monitoring. The best practice is to implement infrastructure-as-code with mandatory peer review for all network changes, combined with continuous cloud security posture management that detects and alerts on deviations from the approved network security baseline within minutes of the change.

VLAN Segmentation and Multi-Tenant Isolation Risks

Definition: Virtual Local Area Networks (VLANs) provide logical network segmentation within shared physical infrastructure, isolating traffic between tenants, between network zones, and between management and workload traffic. VLANs are a logical control: their effectiveness depends entirely on correct configuration.

Business relevance: VLAN segmentation is the primary mechanism by which cloud providers achieve traffic isolation between tenants on shared physical infrastructure. When VLANs are correctly configured, a tenant on one VLAN cannot see or reach traffic on another. When they are misconfigured, that isolation boundary can fail in ways that are not immediately visible to either tenant.

Cloud Security Practitioner relevance: A Cloud Security Practitioner cannot inspect a cloud provider's VLAN configuration directly, but can evaluate the adequacy of a provider's segmentation controls through third-party audit reports (SOC 2 Type II) that test multi-tenant isolation, penetration test results that include inter-tenant isolation testing, and provider documentation of their network isolation architecture. For internal cloud deployments, the practitioner designs and enforces VLAN segmentation policies and verifies them through periodic penetration testing.

Real-world example: During an internal security review at a cloud-based healthcare analytics company, the security team commissions a penetration test specifically targeting inter-segment isolation. The test is designed to simulate what would happen if an attacker compromised a workload in the lower-sensitivity analytics environment and attempted to reach the higher-sensitivity patient data environment, which is placed in a separate VLAN. The penetration testers discover that while the VLAN segmentation is correctly configured at the virtual switch layer, a misconfigured network ACL on one of the transit gateways allows certain traffic to cross the segment boundary under specific conditions. The finding is rated critical because the patient data environment contains protected health information subject to HIPAA. The remediation is a corrected ACL and an updated network segmentation design review process that requires explicit verification of all transit gateway rules whenever segmentation boundaries change.

Risks or limitations: VLAN misconfiguration is difficult to detect from within the affected environments because the isolation failure is not visible to the workloads on either side. The best practice is to include inter-segment isolation testing in every penetration test scope, and to require that any change to network routing or transit gateway configuration triggers a mandatory review of all ACLs and routing rules affecting segmentation boundaries.

BGP Hijacking and Routing Protocol Security

Definition: Border Gateway Protocol (BGP) governs routing between major networks on the internet. BGP hijacking occurs when a network operator advertises routing prefixes they do not legitimately control, causing internet traffic to be redirected through the hijacker's infrastructure, enabling interception, manipulation, or disruption.

Business relevance: BGP hijacking has been used to redirect traffic from cloud services, financial institutions, and telecommunications providers through adversary-controlled infrastructure. Because BGP was designed for trust-based routing rather than cryptographically authenticated routing, it has inherent vulnerabilities that cannot be eliminated simply by choosing a reputable cloud provider.

Cloud Security Practitioner relevance: A Cloud Security Practitioner cannot directly control internet routing infrastructure, but can implement controls that limit the impact of a BGP hijacking event: ensuring all sensitive data in transit is encrypted end-to-end so that intercepted traffic is not readable, monitoring for unexpected routing changes using BGP monitoring services, and for the highest sensitivity workloads, using dedicated private connections that bypass public internet routing entirely.

Real-world example: In 2018, traffic from major cloud providers including Amazon Route 53 was briefly hijacked through a BGP route manipulation that redirected DNS resolution traffic through a network controlled by attackers, enabling them to intercept cryptocurrency wallet credentials. The attack worked because BGP announcements are not cryptographically verified by default: an attacker who can originate a more specific route announcement can attract traffic destined for a legitimate network. The practical lesson for a Cloud Security Practitioner is that even a reputable cloud provider's routing infrastructure can be affected by BGP manipulation that originates outside the provider's network. The control that limits the damage from such an event is end-to-end encryption: traffic that is intercepted but encrypted is not readable. For the highest-risk workloads, dedicated private connectivity eliminates public internet routing exposure entirely.

Risks or limitations: Assuming that encryption at the application layer is unnecessary because the cloud provider manages the network is a dangerous error when BGP hijacking is considered. The best practice is to enforce TLS for all inter-service communication regardless of whether the services appear to be on the same internal network, and to monitor BGP routing announcements for unexpected changes affecting your provider's IP ranges.

Content Delivery Networks and Load Balancers as TLS Termination Points

Definition: Content Delivery Networks (CDNs) distribute content to geographically dispersed cache nodes to reduce latency. Application-layer load balancers distribute traffic across backend instances and often serve as the TLS termination point where inbound encrypted connections are decrypted before forwarding to backend services.

Business relevance: CDNs and load balancers improve performance and resilience, but their role as TLS termination points creates specific security considerations: the path between the load balancer and the backend service may be unencrypted unless explicitly configured otherwise, and content cached in CDN nodes exists in multiple geographic locations simultaneously, which has implications for data residency and the scope of any security incident affecting cached content.

Cloud Security Practitioner relevance: A Cloud Security Practitioner reviewing an architecture that uses a CDN or application load balancer must explicitly verify: whether TLS is re-established between the termination point and the backend service (not just from client to load balancer), whether CDN cache nodes are located in jurisdictions consistent with data residency requirements, and whether CDN cache invalidation controls are in place to remove sensitive content from cache nodes promptly if a data exposure incident occurs.

Real-world example: A European e-commerce company uses a CDN to accelerate delivery of its product catalogue and customer-facing application. During a compliance review for GDPR, the security practitioner discovers that the CDN configuration caches pages that include personalised product recommendations derived from user browsing history. Because CDN cache nodes are distributed globally including in non-EEA jurisdictions, this means personal data is being processed and stored outside the European Economic Area without an appropriate legal transfer mechanism. The issue is remediated by configuring cache control headers to prevent caching of personalised content and by restricting CDN edge locations to EEA-compliant regions for the production environment. The incident also prompts a review of TLS configuration: the practitioner confirms that the company had TLS from client to the CDN edge, but the path from the CDN edge to the origin server was HTTP, meaning customer data traversed an internal network segment without encryption. Both gaps are remediated before the GDPR compliance deadline.

Risks or limitations: Assuming that TLS termination at the load balancer or CDN edge means all traffic is encrypted is a common and dangerous misconfiguration. The best practice is to explicitly verify and document the encryption state of traffic at every hop in the path from client to backend service, and to require TLS on every segment, not just the client-facing one.

Practical Applications

The following scenarios illustrate how cloud network security concepts from this lecture apply in practitioner roles across different organisational contexts.

Evaluating Network Connectivity Options for a Regulated Workload

A cloud security practitioner at a regional bank is designing the connectivity architecture for a new customer loan origination system migrating to a cloud IaaS environment. The system will process personal financial data subject to both national banking regulations and PCI DSS requirements. The practitioner begins the connectivity design by classifying the workload against the organisation's data sensitivity framework, which places personal financial data in the highest sensitivity tier. Per the practitioner's documented decision rule, any workload in the highest sensitivity tier requires dedicated private connectivity unless a specific exception is granted by the Chief Information Security Officer with documented compensating controls. The practitioner documents the recommendation for Azure ExpressRoute with a redundant circuit from two separate points of presence, the technical justification referencing PCI DSS requirement 4.2.1 for strong cryptography in transit and the additional rationale that ExpressRoute eliminates the BGP routing exposure inherent in public internet transit. The design is approved and the ExpressRoute configuration is included in the infrastructure-as-code templates that deploy the environment, ensuring that future redeployments automatically include the correct connectivity controls.

Reviewing SDN Configuration in a Cloud Security Posture Assessment

A practitioner conducting a cloud security posture assessment for a manufacturing company discovers through automated tooling that 14 network security group rules across the company's cloud environment allow inbound traffic from 0.0.0.0/0 on ports other than 80 and 443. Three of these rules expose management ports (SSH on 22, RDP on 3389, and a database port on 1433) to the public internet. The practitioner uses the organisation's cloud infrastructure-as-code repository to trace each rule to its originating commit, identifying which team created the rule and when. The investigation reveals that all three exposures resulted from developers copying rule templates from test environments into production environments without adjusting the source IP range. The practitioner documents each finding with severity, affected resources, originating team, duration of exposure, and recommended remediation. The remediation recommendations specify exactly which source IP ranges each rule should be restricted to, based on the documented network architecture. The practitioner also recommends

implementing a preventive control: a policy-as-code rule that blocks any network security group change opening a management port to 0.0.0.0/0 before it is applied, eliminating the class of misconfiguration at source rather than detecting it after the fact.

Assessing Multi-Tenant Isolation in a Cloud Provider Evaluation

A practitioner at a legal services firm is evaluating two cloud providers for a matter management system that will contain privileged attorney-client communications. Multi-tenant network isolation is a critical requirement: if a co-tenant on shared infrastructure could access the firm's network traffic, that would constitute a breach of privilege. The practitioner requests SOC 2 Type II reports from both providers and identifies the specific control objectives related to logical access and network separation. Provider A's report includes a test result that explicitly covers inter-tenant network isolation and reports no exceptions. Provider B's report covers logical access controls broadly but does not include a specific test for inter-tenant network segment isolation. The practitioner contacts Provider B to request supplementary evidence, and is provided with a vendor attestation rather than an independent test result. The practitioner documents this gap in the evaluation: Provider A has independent evidence of tested inter-tenant network isolation; Provider B has a vendor attestation only. The recommendation to use Provider A for the matter management system is supported by this documented evidence, and the evaluation record is retained for the firm's compliance files.

Best Practices

- **Classify all cloud workloads by data sensitivity before selecting a connectivity model.** Establish a documented classification framework with at minimum three tiers (public, internal, restricted). Map each tier to an approved connectivity model: restricted workloads require dedicated private connections; internal workloads may use VPN with mandatory TLS; public-facing workloads use internet connectivity with TLS enforcement. Apply this framework at the start of every new workload design and document the classification and connectivity decision in the workload's architecture record.
- **Implement policy-as-code controls that prevent high-risk network security group configurations from being applied.** Deploy a policy enforcement framework that evaluates all proposed network security group changes against defined rules before they are applied to the environment. At minimum, block rules that open management ports (22, 3389, 1433, 5432, 3306) to 0.0.0.0/0, rules that remove encryption requirements from inter-service communication paths, and rules that create direct routing between high-sensitivity and low-sensitivity network segments. Alert on policy violations with the specific rule text and the identity of the change initiator.
- **Verify TLS encryption at every hop in the traffic path, not only at the client-facing edge.** When reviewing or designing architectures that include CDNs, load balancers, or API gateways as TLS termination points, explicitly document the encryption state of traffic at each subsequent hop: from the termination point to any backend service, between microservices, and to any external dependency. Require TLS on every segment and document the certificate management process for each TLS-protected connection. Never assume that TLS at the edge means end-to-end encryption.
- **Require independent evidence of inter-tenant network isolation when evaluating cloud providers for sensitive workloads.** When a prospective cloud provider's SOC 2 Type II report does not include a specific test result for inter-tenant network segment isolation, do not accept a vendor attestation as a substitute. Request independent penetration test results that specifically cover inter-tenant isolation, or escalate to an on-site assessment if the workload's sensitivity warrants it. Document the evidence obtained and any gaps in the evaluation record.

- **Monitor BGP routing announcements for unexpected changes affecting your cloud provider's IP prefixes.** Subscribe to a BGP monitoring service and configure alerts for any route announcement changes affecting the IP address ranges used by your cloud provider. While you cannot control internet routing infrastructure, early detection of a BGP hijacking event allows you to activate incident response procedures, notify affected users, and review logs for the period of the anomalous routing to assess whether traffic was intercepted. Combine this monitoring with end-to-end encryption enforcement to limit the impact of any interception that occurs.

Common Mistakes and Misconceptions

Misconception: Treating network security as equivalent to network availability — assuming that if the network is up and performant, it is also secure.

Correct approach: Availability and security are independent properties. The best practice is to evaluate cloud network architectures against both dimensions separately, with specific security questions: Is all sensitive data encrypted in transit on every segment? Are network security group rules consistent with the principle of least privilege? Is management traffic segmented from workload traffic? Are VLAN configurations independently tested for inter-tenant isolation?

Misconception: Using public internet connectivity for sensitive or regulated workloads without explicit documented justification and compensating controls.

Correct approach: The correct approach is to classify workloads by data sensitivity at design time and require dedicated private connectivity (Direct Connect, ExpressRoute, Cloud Interconnect) as the default for sensitive workloads. If public internet connectivity is used, the justification must be documented, compensating controls (TLS enforcement, certificate pinning, end-to-end encryption) must be specified, and the decision must be reviewed at each annual risk assessment.

Misconception: Accepting a vendor's assertion that multi-tenant network isolation is implemented without requesting independent evidence.

Correct approach: Multi-tenant isolation is a security property that requires independent verification. The best practice is to request the relevant sections of a SOC 2 Type II report that include specific test results for inter-tenant network segment isolation, not just logical access controls broadly. Where independent audit evidence does not exist, commission your own penetration test targeting inter-tenant isolation before placing sensitive workloads in the environment.

Misconception: Assuming TLS termination at a load balancer or CDN edge means all traffic in the environment is encrypted.

Correct approach: TLS termination decrypts traffic at the point of termination. Traffic from that point to backend services may be unencrypted unless explicitly configured otherwise. The best practice is to document the encryption state at every hop and require TLS on every segment, configuring origin-pull TLS on CDNs and backend TLS on load balancers regardless of whether the segments are considered 'internal.'

table: Cloud Network Component Security Evaluation Matrix

Use this matrix when evaluating the security configuration of cloud network components. For each component, verify the listed security properties and document the evidence or configuration confirming each property is in place.

Network Component	Key Security Property	Verification Method	Common Failure Mode
Private Backbone / Dedicated Connection	Traffic does not traverse public internet	Review connectivity type in architecture; confirm Direct Connect / ExpressRoute / Cloud Interconnect order documentation	Workload using public internet connectivity without documented justification
Software-Defined Network (SDN)	Changes require peer review; policy-as-code prevents high-risk rules	Review infrastructure-as-code repository for network changes; confirm policy-as-code framework is active	Manual console changes bypassing version control and review process
VLAN Segmentation	Inter-tenant and inter-zone isolation is independently tested	Review SOC 2 Type II for inter-tenant isolation test results; review internal penetration test scope	Relying on vendor attestation rather than independent test evidence
BGP / Internet Routing	Sensitive traffic is encrypted end-to-end; BGP monitoring is active	Confirm TLS enforcement on all sensitive data paths; confirm BGP monitoring subscription and alert configuration	Unencrypted inter-service traffic that would be readable if intercepted
CDN / Load Balancer	TLS is enforced on all segments, including edge-to-origin	Review CDN and load balancer configuration for origin-pull TLS; confirm certificate management process	TLS from client to edge but HTTP from edge to origin
VPN (Site-to-Site / Remote Access)	Encryption algorithm and key length meet current standards; credentials at both endpoints are protected	Review VPN configuration for deprecated algorithms (3DES, RC4); confirm MFA for remote access VPN	VPN protecting transit while weak credentials at an endpoint are compromised

How to use this: This matrix should be completed as part of every cloud architecture review and cloud provider evaluation. Evidence gathered for each row should be retained in the architecture record. Gaps identified should be treated as findings requiring remediation or documented risk acceptance.

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. A cloud security practitioner is reviewing the connectivity design for a new workload that will process cardholder data subject to PCI DSS requirements. The proposed design uses public internet connectivity with TLS encryption for all traffic. Which response best reflects the CCSP approach to evaluating this design?

- A) A. The design is acceptable because TLS encryption satisfies PCI DSS requirement 4.2.1 for strong cryptography in transit.
- B) B. The design should be documented and accepted because public internet connectivity is the default for cloud workloads.
- C) C. The practitioner should recommend dedicated private connectivity (such as Direct Connect or ExpressRoute) as the preferred control for cardholder data workloads, with public internet connectivity requiring documented justification and CISO approval.
- D) D. The design is non-compliant with PCI DSS because PCI DSS prohibits the use of public internet connectivity for cardholder data.

Answer: C. The practitioner should recommend dedicated private connectivity (such as Direct Connect or ExpressRoute) as the preferred control for cardholder data workloads, with public internet connectivity requiring documented justification and CISO approval.

Q2. A developer adds a network security group rule opening TCP port 5432 to 0.0.0.0/0 for a PostgreSQL database, intending to restrict access to a single IP but making a typographical error. The misconfiguration exposes the database to the public internet for three weeks before detection. Which preventive control would most directly have prevented this incident?

- A) A. A mandatory 48-hour change freeze before any network security group modification takes effect.
- B) B. A policy-as-code framework that automatically validates all network security group changes against defined rules and blocks any rule opening database ports to 0.0.0.0/0 before the change is applied.
- C) C. Quarterly penetration testing that includes a review of all network security group configurations.
- D) D. A requirement that all network security group changes be submitted as formal change requests reviewed at the monthly change advisory board.

Answer: B. A policy-as-code framework that automatically validates all network security group changes against defined rules and blocks any rule opening database ports to 0.0.0.0/0 before the change is applied.

Q3. A cloud security practitioner is evaluating a CDN architecture for a GDPR-regulated e-commerce application. The CDN terminates TLS at the edge and delivers personalised content to users. Which of the following represents the most significant security and compliance concern in this scenario?

- A) A. CDN edge nodes may introduce additional latency that affects user experience.
- B) B. Personalised content cached on CDN nodes in non-EEA jurisdictions may constitute international personal data transfer without a legal basis, and the path from the CDN edge to the origin server may be unencrypted.
- C) C. TLS termination at the CDN edge means the CDN provider can read all customer traffic, which is prohibited under GDPR.
- D) D. CDN cache invalidation is too slow to meet GDPR's 72-hour breach notification requirement.

Answer: B. Personalised content cached on CDN nodes in non-EEA jurisdictions may constitute international personal data transfer without a legal basis, and the path from the CDN edge to the origin server may be unencrypted.

Q4. BGP hijacking allows an attacker to redirect internet traffic through infrastructure they control. Which of the following controls provides the most direct protection against the consequences of a BGP hijacking event affecting a cloud workload?

- A) A. Implementing DNSSEC to authenticate DNS resolution responses for the workload's domain.
- B) B. Requiring all cloud workloads to use static IP addresses rather than load balancers.
- C) C. Enforcing end-to-end TLS encryption for all sensitive data in transit, so that intercepted traffic is not readable even if routing is manipulated.
- D) D. Deploying a web application firewall in front of the workload to inspect and block malicious traffic.

Answer: C. Enforcing end-to-end TLS encryption for all sensitive data in transit, so that intercepted traffic is not readable even if routing is manipulated.

Reflection Questions

1. Think about a cloud workload you are currently responsible for or familiar with. What type of connectivity does it use, and is that connectivity choice documented and justified relative to the sensitivity of the data it processes?
2. When was the last time the network security group configurations in a cloud environment you work in were reviewed against the principle of least privilege? What process would you use to conduct that review?
3. How would you explain the difference between network availability and network security to a business stakeholder who is satisfied that the cloud network is 'working fine'?
4. If you were evaluating two cloud providers for a regulated workload and one had an independent penetration test result confirming inter-tenant network isolation while the other had only a vendor attestation, how would you use that difference in your evaluation and what would you document?
5. What would need to change in your current cloud environment to implement policy-as-code enforcement that blocks high-risk network security group rules before they are applied?

Key Takeaways

- Cloud network infrastructure encompasses physical backbone connectivity, software-defined logical overlays, routing protocols, and management interfaces, each with a distinct attack surface and set of security controls.
- Dedicated private connectivity services (AWS Direct Connect, Azure ExpressRoute, Google Cloud Interconnect) eliminate public internet routing exposure for sensitive workloads and should be the default recommendation for regulated data.
- Software-defined networking concentrates misconfiguration risk: the speed that makes SDN powerful also means errors propagate instantly. Policy-as-code enforcement and continuous posture monitoring are the appropriate preventive controls.
- VLAN segmentation is a logical control whose effectiveness depends entirely on correct configuration. Independent testing of inter-tenant isolation through SOC 2 Type II audits or penetration tests is required evidence, not vendor attestation.
- BGP hijacking can redirect traffic through adversary-controlled infrastructure. End-to-end TLS encryption limits the damage from such events; dedicated private connections eliminate public internet routing exposure entirely.
- TLS termination at a CDN edge or load balancer does not mean all traffic is encrypted: the path from the termination point to backend services must be independently verified and explicitly configured for TLS.
- Availability and security are independent network properties. A highly available, high-performance cloud network can simultaneously have unencrypted inter-service paths, exposed management interfaces, and misconfigured segmentation.

Recommended Next Actions

Put this lecture to work within the next seven days:

6. Audit the connectivity type for every cloud workload in your environment this week. For each workload, document whether it uses public internet, VPN, or dedicated private connectivity, and whether that choice is consistent with the workload's data sensitivity classification.

7. Review the network security group or firewall rule configurations in one cloud environment you manage. Identify any rules that open management ports (22, 3389, 1433, 5432, 3306) to source ranges broader than the documented management IP range, and remediate or document each as a finding.
8. Locate the SOC 2 Type II report for one cloud provider you use and identify whether it includes a specific test result for inter-tenant network segment isolation. If it does not, draft a request for supplementary evidence to send to the provider.
9. For one CDN or load balancer configuration in your environment, verify the encryption state of traffic from the termination point to the backend services. Document whether origin-pull TLS is configured and whether TLS certificates on the backend path are being managed and renewed.